

Министерство цифрового развития, связи и массовых коммуникаций
Российской Федерации
Ордена Трудового Красного Знамени федеральное государственное
бюджетное образовательное учреждение высшего образования
**«МОСКОВСКИЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ СВЯЗИ И
ИНФОРМАТИКИ»
(МТУСИ)**

Кафедра «Сетевые информационные технологии и сервисы»

Проектная работа

По дисциплине «Управление проектированием информационных систем»

Корпоративный портал ИСПДн

Выполнили:

Студенты
группы М092201(71)

Барсов М.

Очиров А.

Дубровин Н.

Проверил:

Старший преподаватель,
Маклачкова В.В.

Москва, 2023

СОДЕРЖАНИЕ

ЦЕЛЬ РАБОТЫ	3
1	Описание ИСПДн 4
1.1	Описание объекта исследования 4
1.2	Описание данных, хранимых в ИСПДн организации 5
	Описание характеристик ИСПДн организации 8
1.3	Описание процессов обработки ПДн в организации 13
2.	ПЕРЕЧЕНЬ НОРМАТИВНЫХ ДОКУМЕНТОВ 36
3	ВОЗМОЖНЫЕ НЕГАТИВНЫЕ ПОСЛЕДСТВИЯ ОТ РЕАЛИЗАЦИИ (ВОЗНИКНОВЕНИЯ) УГРОЗ БЕЗОПАСНОСТИ ИНФОРМАЦИИ 37
3.1	Определение возможных объектов взаимодействия, интерфейсов доступа и возможные виды воздействия на них 37
3.2	MITRE ATT&CK 39
ВЫВОДЫ	41

ЦЕЛЬ РАБОТЫ

Необходимо выдвинуть требования на разработку и обоснование выдвигаемых рекомендаций по обеспечению безопасности персональных данных, которая послужит основой для разработки и проведения мероприятий по проектированию и внедрению системы обеспечения безопасности персональных данных в информационной системе «Корпоративный портал», в ходе работы необходимо провести анализ возможностей нарушителей, который позволит выявить класс криптосредств, предполагаемых для использования в ИСПДн, а также провести оценку угроз информационной безопасности на примере существующей, используя методику оценки угроз информационной безопасности, утверждённую ФСТЭК России 05.02.2021(далее принято следующее сокращение – Методика).

План выполнения задания:

- Описать ИСПДн, определить характеристики ИСПДн и схему этого сегмента, указать классы защищенности и описание основных процессов взаимодействия с организацией
- Определить тип угроз, актуальных для ИСПДн (п.6 ПП №1119)
- Определить вид ИСПДн (п.5 ПП №1119)

Определить категории обрабатываемых ПДн (п.5 ПП№1119)
Определить уровень защищённости ПДн. (п.8 ПП№1119)
Состав и содержание технических и организационных мер по защите ПДн (ФСТЭК № 21, ПП № 1119 и приказом ФСБ № 378)
Возможные негативные последствия от реализации (возникновения) угроз безопасности информации

Описание ИСПДн

Описание объекта исследования

В рамках выполнения задания рассматриваемым объектом исследования является «Корпоративный портал». Его физическая инфраструктура предполагает наличие нескольких географически-распределенных территориальных объектов, объединенных в единую корпоративную информационную систему (КИКС). Рассматриваемая система представляет из себя информационную систему, которая выполняет функции управления внутренними процессами компании: предоставление доступа к информации сотрудникам, автоматизация и оптимизации бизнес-процессов, обучение и развитие персонала.

На рисунке 1.1 приведена схема сети рассматриваемого предприятия.

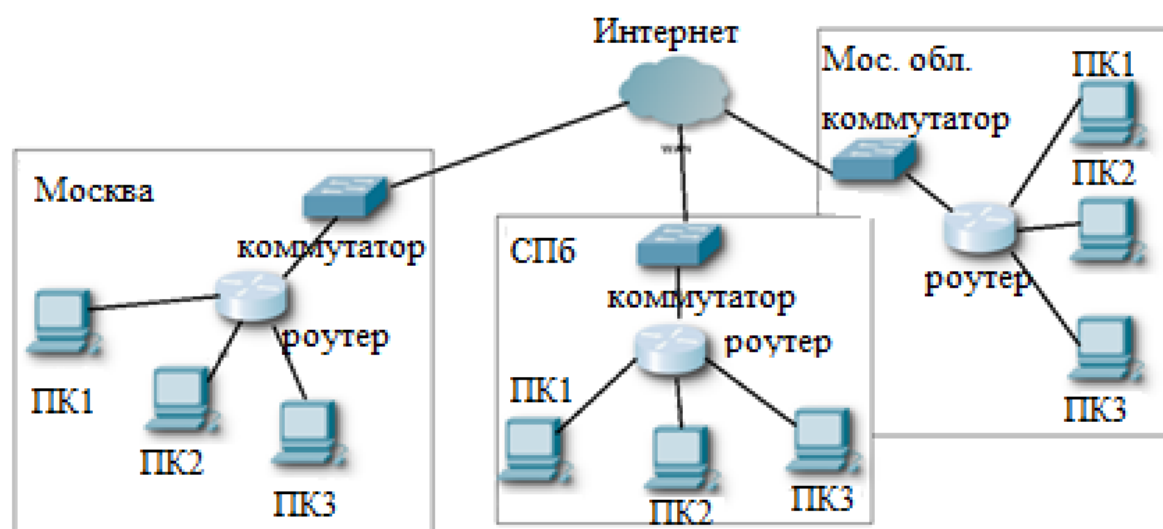


Рисунок 1.1 Схема сети предприятия.

Архитектуры системы обработки персональных данных для исследуемой организации, представляет из себя совокупность:

Сети центрального офиса, расположенного в Москве;
 Сетей филиалов корпоративного портала (Московская область, Санкт-Петербург);
 Информационной сети персональных данных 1С Предприятие;
 Информационной сети персональных данных Корпоративный портал.

Архитектура сегмента сети 1С Предприятие, участвующего в обработке ПДн представлена на рисунке 1.2:

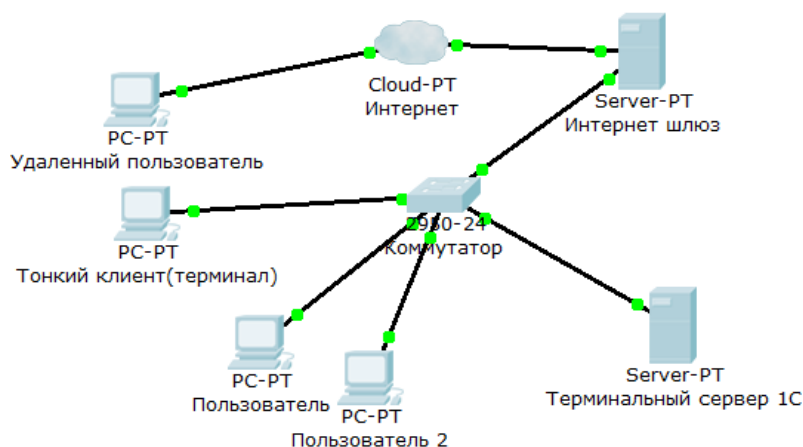


Рисунок 1.2 Архитектура ИСПДн 1 1С Предприятие.

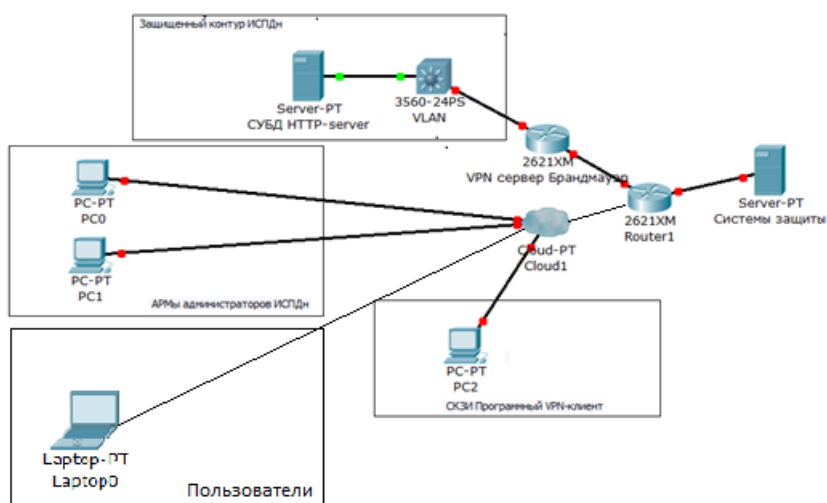


Рисунок 1.3 Архитектура ИСПДн 2 Корпоративный портал.

Описание данных, хранимых в ИСПДн организации

В рассматриваемой ИСПДн «Корпоративный портал» хранятся и обрабатываются следующие группы персональных данных:

ПДн сотрудников (в т.ч. уволенных);

ПДн кандидатов на вакантные места.

Полный перечень, обрабатываемых ПДн приведен в таблице 1.1.

Таблица 1.1. – Перечень ПДн, обрабатываемых в АС объекта исследования.

Группа персональных данных	Содержание сведений
Персональные данные сотрудников (в т.ч. уволенных)	
Паспортные данные	ФИО
	Фотография
	Дата и место рождения
	Серия и номер паспорта
	Пол
	Гражданство
	Кем и когда выдан паспорт
	Адрес прописки
	Семейное положение
Сведения о трудовой деятельности	ФИО
	Должность
	Департамент
	Дата приема на работу
	Сведения из трудовой книжки
	Сведения о воинском учете
	Данные трудового договора
Контактная информация	ФИО
	Адрес
	Контактный телефон
	Эл. почта

	Доп. способ для связи (Профиль из социальных сетей, может быть несколько)
Данные налогового учета	ФИО
	ИНН
	Данные о банковской карте
Персональные данные кандидатов на вакантные места	
Паспортные данные	ФИО
	Фотография
	Дата и место рождения
	Серия и номер паспорта
	Пол
	Гражданство
	Кем и когда выдан паспорт
	Адрес прописки
	Семейное положение
Сведения о трудовой деятельности	ФИО
	Должность
	Департамент
	Дата приема на работу
	Сведения из трудовой книжки
	Сведения о воинском учете
	Данные трудового договора
Контактная информация	ФИО
	Адрес
	Контактный телефон
	Эл. почта
	Доп. способ для связи (Профиль из социальных сетей, может быть несколько)

Данные налогового учета	ФИО
	ИНН
	Данные о банковской карте

Описание характеристик ИСПДн организации

На основании результатов, полученных при исследовании информационных систем обработки персональных данных «Корпоративный портал» для каждой ИСПДн определяется структура, характеризующая соответствующим режимом обработки.

Для каждой из ИСПДн определяется:

- категория обрабатываемых ПДн: общедоступные;
- объем обрабатываемых ПДн: от 100 000;
- характеристики безопасности ПДн: конфиденциальность, целостность, доступность;
- структура: распределенная, находится в разных регионах в городах Российской Федерации;
- подключение информационной системы к сетям общего пользования и/или сетям международного информационного обмена: С АРМ производится доступ к сетям связи общего пользования информационные системы, с разграничением прав доступа;
- режим обработки ПДн: многопользовательский
- режим разграничения прав доступа пользователей: есть;
- местонахождение технических средств информационной системы: Все технические средства ИСПДн находятся в пределах Российской Федерации.

Пример

ИСПДн «Корпоративный портал» является территориально-распределенной автоматизированной информационной системой, границы которой определены в рамках головного офиса и филиалов. Комплекс технических средств ИСПДн «Корпоративный портал» включает средства обработки данных (ПЭВМ, сервера БД, почтовый сервер и т.п.), средства обмена данными в ЛВС (кабельная система, и т.д.), а также средства хранения (в т.ч. архивирования) данных.

По результатам проведения анализа ПДн, обрабатываемых в ИСПДн объекта исследования, отделов и сотрудников, имеющих доступ к ПДн производится описание автоматизированных систем, осуществляющих обработку ПДн. В «Корпоративном портале» рассматриваются 2 ИСПДн:

1С: Предприятие;

Информационная сеть Корпоративного портала;

Подробное описание характеристик, определенных выше приведено в таблице 1.2.

Таблица 1.2 – перечень информационных систем персональных данных

№ п/п	Полное и сокращенное название ИСПДн	Исходные данные для необходимого уровня защищенности ПДн
1	Информационная система персональных данных «1С Предприятие»/ИСПДн «1С Предприятие»	категория обрабатываемых ПДн: иные объем обрабатываемых ПДн: менее 100 000; характеристики безопасности ПДн: конфиденциальность, целостность, доступность; структура: распределенная,

		находится в разных регионах в городах Российской Федерации; подключение информационной системы к сетям общего пользования и/или сетям международного информационного обмена: С АРМ производится доступ к сетям связи общего пользования информационные системы, с разграничением прав доступа; режим обработки ПДн: многопользовательский режим разграничения прав доступа пользователей: есть; местонахождение технических средств информационной системы: Все технические средства ИСПДн находятся в пределах Российской Федерации.
2	Информационная сеть Корпоративный портала	категория обрабатываемых ПДн: общедоступные объем обрабатываемых ПДн: более 100 000;

		характеристики безопасности ПДн: конфиденциальность, целостность, доступность; структура: распределенная, находится в разных регионах в городах Российской Федерации; подключение информационной системы к сетям общего пользования и/или сетям международного информационного обмена: С АРМ производится доступ к сетям связи общего пользования информационные системы, с разграничением прав доступа; режим обработки ПДн: многопользовательский режим разграничения прав доступа пользователей: есть; местонахождение технических средств информационной системы: Все технические средства ИСПДн находятся в пределах Российской Федерации.
--	--	--

Далее производится описание перечня действий и задач, реализуемых в идентифицированных ИСПДн.

ИСПДн «1С предприятие» реализует задачу автоматизации управления. В ней хранятся данные: ФИО, паспортные данные, адрес проживания, ИНН, банковские реквизиты, сведения о заработной плате к выплате.

Субъекты персональных данных:

Сотрудники предприятия, контрагенты (физические лица).

Действия, осуществляемые с данными в ходе их обработки:

Обработка персональных данных осуществляется с целью предоставления субъектам персональных данных функции управления внутренними процессами компании и исполнения своих обязательств в рамках договорных отношений и действующего законодательства Российской Федерации. Обработка персональных данных покупателей осуществляется для решения следующих задач:

формирование и обработка документов с целью автоматизации внутренних процессов компании;
поддержание контактов с субъектом персональных данных;
иные задачи, необходимые для повышения качества и эффективности деятельности Корпоративного портала.

В ИСПДн 1С Предприятие осуществляются следующие операции с ПДн: запись, систематизация, накопление, уточнение (обновление\редактирование), извлечение, использование, передача, обезличивание, блокирование, удаление.

ИСПДн «Корпоративный портал» реализует задачу автоматизации бизнес-процессов. В ней хранятся данные: ФИО, адрес проживания, ИНН, банковские реквизиты, контактные данные сотрудников.

Субъекты персональных данных:

контрагенты (Юридические лица);
сотрудники (Физические лица).

В ИСПДн Корпоративный портал осуществляются следующие операции с ПДн: запись, систематизация, накопление, уточнение (обновление\редактирование), извлечение, использование, передача, обезличивание, блокирование, удаление.

Описание процессов обработки ПДн в организации

С точки зрения процессов, связанных с обработкой ПДн в организации можно выделить перечень, содержащий факты получения, обработки или хранения персональных данных. Обнаруженные процессы условно разделяются на следующие группы:

- предоставление доступа к информации сотрудников;
- расчетные операции с сотрудниками;
- автоматизация бизнес-процессов.

Хранение ПДн, участвующих в вышеперечисленных типах процессов может быть реализовано на следующих серверах БД и в электронных хранилищах организации:

БД ПО «1С Управление предприятием 2.9» (SQL база 1С);

ОС ПО Windows Server 2019 или Astra Linux.

Полный перечень, процессов связанных с обработкой ПДн в объекте исследования приведен в таблицах 1.3 – 1.4. Он включает описание процесса, исполнителя, осуществляющего его выполнение, используемое ПО, участвующие ИСПДн, а также используемые документы для осуществления операции/процесса:

Таблица 1.3 – Предоставление доступа к информации сотрудников

№	Наименование операции	Исполнитель	Используемое программное обеспечение	Используемые документы
1	Регистрация сотрудника в Корпоративном портале	Администратор	Корпоративный портал	Заявление на регистрацию, согласие на обработку

				персональн ых данных, резюме, трудовой договор
2	Модерация страницы сотрудника	Модератор корпоративн ого портала	Сайт «Корпоратив ный портал»	Согласие с правилами Сайта, согласие на обработку персональн ых данных
3	Удаление страницы сотрудника	Администра тор и модератор корпоративн ого портала	Сайт «Корпоратив ный портал»	Согласие на обработку персональн ых данных, расторжени е трудового договора, запрос на удаление персональн ых данных

Таблица 1.4 – Расчетные операции с работниками

№	Наименован ие операции	Исполнител ь	Используй мое программ ное обеспечени е	Используй мые документы

1	Ведение лицевого счета	Сотрудники бухгалтерии, главный бухгалтер	1С Бухгалтерия	Лицевые счета
2	Выплата заработной платы сотрудникам	Сотрудники бухгалтерии	1С Бухгалтерия	Расчетно-платежные ведомости
3	Трудоустройство сотрудников Корпоративного портала	Сотрудники Корпоративного портала	1С Предприятие	Оформление трудового договора
4	Увольнение сотрудников Корпоративного портала	Сотрудники Корпоративного портала	1С Предприятие	Расторжение трудового договора

Сводка по средствам защиты

В Компании «Корпоративный портал» установлены следующие средства защиты:

Таблица 1.7 Применяемые средства защиты

№	Наименование средства защиты	Назначение
1	Операционная система Microsoft Windows Server 2016 VL Standard/Datacenter (Rus/Eng) Build 10.0.14393.1794 x64 со встроенными и дополнительно интегрируемыми механизмами обеспечения безопасности, реализуемыми средством защиты	соответствует Требованиям к средствам защиты информации ограниченного доступа, не содержащей сведений, составляющих государственную

	информации «Secure Pack Rus версия 3.0 (исполнения 7, 8)»	тайну, от несанкционированного доступа, по уровню АК3 (для исполнения 7), по уровню АК2 (для исполнения 8) и может использоваться для защиты информации, не содержащей сведений, составляющих государственную тайну, при условии выполнения требований эксплуатационной документации согласно формуляру ЖТЯИ.00106-01 30 01
2	Программное антивирусное средство Kaspersky Endpoint Security 11.3 для Windows	соответствует требованиям ФСБ России к программным антивирусным средствам, используемым в средствах вычислительной техники, эксплуатируемых в органах федеральной службы безопасности, классов Б2, В2, Г2 и может использоваться для защиты информации,

		содержащей сведения, составляющие государственную тайну, при условии выполнения требований эксплуатационной документации согласно формуляру 643.46856491.20100 03 30 01
3	ViPNet CSP 4.4 (Версия 4.4.2) (исполнения 1, 2, 3, 4, 5, 6)	соответствует Требованиям к средствам криптографической защиты информации, предназначенным для защиты информации, не содержащей сведений, составляющих государственную тайну, класса КС1 (для исполнений 1, 4), класса КС2 (для исполнений 2, 5), класса КС3 (для исполнений 3, 6), Требованиям к средствам электронной подписи, утвержденным приказом ФСБ России от 27 декабря 2011 г. № 796, установленным для класса КС1 (для

		исполнений 1, 4), класса КС2 (для исполнений 2, 5), класса КС3 (для исполнений 3, 6) и может использоваться для криптографической защиты (создание и управление ключевой информацией, шифрование файлов и данных, содержащихся в областях оперативной памяти, вычисление имитовставки для файлов и данных, содержащихся в областях оперативной памяти, вычисление значения хэш-функции для файлов и данных, содержащихся в областях оперативной памяти, защита TLS- соединений, реализация функций электронной подписи в соответствии с Федеральным законом от 6 апреля 2011 г. № 63 ФЗ «Об электронной подписи»: создание электронной подписи, проверка электронной
--	--	---

		подписи, создание ключа электронной подписи, создание ключа проверки электронной подписи) информации, не содержащей сведений, составляющих государственную тайну
--	--	--

Таблица 2 – Определение уровня защищенности ПДн

Тип ИСПДн	Категории субъектов	Количество субъектов	Тип актуальных угроз		
			1	2	3
ИСПДн, в которых обрабатываются ПДн специальных категорий	не сотрудники	менее 100 000	УЗ1	УЗ1	УЗ2
		более 100 000	УЗ1	УЗ2	УЗ3
	сотрудники	менее 100 000	УЗ1	УЗ2	УЗ3
		более 100 000	УЗ1	УЗ2	УЗ
ИСПДн, в которых обрабатываются биометрические ПДн	не сотрудники	менее 100 000	УЗ2	УЗ3	УЗ4
		более 100 000	УЗ2	УЗ2	УЗ4
	сотрудники	менее 100 000	УЗ2	УЗ1	УЗ3

		более 100 000	У31	У32	У34
ИСПДн, в которых обрабатываются иные категории ПДн	не сотрудники	менее 100 000	У34	У32	У3
		более 100 000	У32	У33	У34
	сотрудники	менее 100 000	У32	У32	У34
		более 100 000	У32	У33	У34

Для определённого уровня защищённости ПДн выписаны меры по обеспечению безопасности ПДн, обозначенные знаком "+".

Таблица 3 – Содержание мер по обеспечению безопасности ПДн

Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
I. Идентификация и аутентификация субъектов доступа и объектов доступа (ИАФ)					
ИАФ.1	Идентификация и аутентификация пользователей, являющихся работниками оператора	+	+	+	+
ИАФ.2	Идентификация и аутентификация устройств, в том числе стационарных, мобильных и портативных				+
ИАФ.3	Управление идентификаторами, в том числе создание, присвоение, уничтожение идентификаторов			+	+

ИАФ.4	Управление средствами аутентификации, в том числе хранение, выдача, инициализация, блокирование средств аутентификации и принятие мер в случае утраты и (или) компрометации средств аутентификации ИСКЛЮЧЕНО ИЗ МЕР				
ИАФ.5	Защита обратной связи при вводе аутентификационной информации ИСКЛЮЧЕНО ИЗ МЕР				
ИАФ.6	Идентификация и аутентификация пользователей, не являющихся работниками оператора (внешних пользователей)	+	+	+	+
II. Управление доступом субъектов доступа к объектам доступа (УПД)					
УПД.1	Управление (заведение, активация, блокирование и уничтожение) учетными записями пользователей, в том числе внешних пользователей	+	+	+	+
Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
УПД.2	Реализация необходимых методов (дискреционный, мандатный, ролевой или иной метод), типов (чтение, запись, выполнение или иной тип) и правил разграничения доступа	+	+	+	+
УПД.3	Управление (фильтрация, маршрутизация, контроль соединений, однонаправленная передача и иные способы управления) информационными потоками между устройствами, сегментами информационной системы, а также между информационными системами			+	+
УПД.4	Разделение полномочий (ролей) пользователей, администраторов и лиц, обеспечивающих функционирование информационной системы			+	+

УПД.5	Назначение минимально необходимых прав и привилегий пользователям, администраторам и лицам, обеспечивающим функционирование информационной системы			+	+
УПД.6	Ограничение неуспешных попыток входа в информационную систему (доступа к информационной системе)			+	+
УПД.7	Предупреждение пользователя при его входе в информационную систему о том, что в информационной системе реализованы меры по обеспечению безопасности персональных данных, и о необходимости соблюдения установленных оператором правил обработки персональных данных	+	-	+	+
УПД.8	Оповещение пользователя после успешного входа в информационную систему о его предыдущем входе в информационную систему				+
УПД.9	Ограничение числа параллельных сеансов доступа для каждой учетной записи пользователя информационной системы ИСКЛЮЧЕНО ИЗ МЕР				
УПД.10	Блокирование сеанса доступа в корпоративный портал			+	+
Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
	после установленного времени бездействия (неактивности) пользователя или по его запросу				
УПД.11	Разрешение (запрет) действий пользователей, разрешенных до идентификации и аутентификации		+	+	+

УПД.12	Поддержка и сохранение атрибутов безопасности (меток безопасности), связанных с информацией в процессе ее хранения и обработки	+	+	+	+
УПД.13	Реализация защищенного удаленного доступа субъектов доступа к объектам доступа через внешние информационно-телекоммуникационные сети		+	+	+
УПД.14	Регламентация и контроль использования в информационной системе технологий беспроводного доступа			+	+
УПД.15	Регламентация и контроль использования в информационной системе мобильных технических средств			+	+
УПД.16	Управление взаимодействием с информационными системами сторонних организаций (внешние информационные системы)			+	+
УПД.17	Обеспечение доверенной загрузки средств вычислительной техники			+	+
III. Ограничение программной среды (ОПС)					
ОПС.1	Управление запуском (обращениями) компонентов программного обеспечения, в том числе определение запускаемых компонентов, настройка параметров запуска компонентов, контроль за запуском компонентов программного обеспечения	+	+	-	-
ОПС.2	Управление установкой (инсталляцией) компонентов программного обеспечения, в том			+	+
Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1

	числе определение компонентов, подлежащих установке, настройка параметров установки компонентов, контроль за установкой компонентов программного обеспечения				
ОПС.3	Установка (инсталляция) только разрешенного к использованию программного обеспечения и (или) его компонентов				+
ОПС.4	Управление временными файлами, в том числе запрет, разрешение, перенаправление записи, удаление временных файлов	+			
IV. Защита машинных носителей персональных данных (ЗНИ)					
ЗНИ.1	Учет машинных носителей персональных данных			+	+
ЗНИ.2	Управление доступом к машинным носителям персональных данных			+	+
ЗНИ.3	Контроль перемещения машинных носителей персональных данных за пределы контролируемой зоны			+	+
ЗНИ.4	Исключение возможности несанкционированного ознакомления с содержанием персональных данных, хранящихся на машинных носителях, и (или) использования носителей персональных данных в иных информационных системах			+	+
ЗНИ.5	Контроль использования интерфейсов ввода (вывода) информации на машинные носители персональных данных			+	+
ЗНИ.6	Контроль ввода (вывода) информации на машинные носители персональных данных			+	+
ЗНИ.7	Контроль подключения машинных носителей персональных данных		+	+	+
ЗНИ.8	Уничтожение(стирание) или обезличивание персональных данных на машинных носителях		+	+	+

Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
	при их передаче между пользователями, в сторонние организации для ремонта или утилизации, а также контроль уничтожения (стирания) или обезличивания				
V. Регистрация событий безопасности (РСБ)					
РСБ.1	Определение событий безопасности, подлежащих регистрации, и сроков их хранения	+	+	+	+
РСБ.2	Определение состава и содержания информации о событиях безопасности, подлежащих регистрации	+	+	+	+
РСБ.3	Сбор, запись и хранение информации о событиях безопасности в течение установленного времени хранения	+	+	+	+
РСБ.4	Реагирование на сбои при регистрации событий безопасности, в том числе аппаратные и программные ошибки, сбои в механизмах сбора информации и достижение предела или переполнения объема (емкости) памяти	+	+	+	+
РСБ.5	Мониторинг (просмотр, анализ) результатов регистрации событий безопасности и реагирование на них			+	+
РСБ.6	Генерирование временных меток и (или) синхронизация системного времени в информационной системе	+	+	+	+
РСБ.7	Защита информации о событиях безопасности	+	+	+	+
VI. Антивирусная защита (AB3)					
AB3.1	Реализация антивирусной защиты	+	+	+	+

AB3.2	Обновление базы данных признаков вредоносных компьютерных программ (вирусов)	+	+	+	+
VII. Обнаружение вторжений (COB)					
COB.1	Обнаружение вторжений			+	+
Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
COB.2	Обновление базы решающих правил			+	+
VIII. Контроль (анализ) защищенности персональных данных (АНЗ)					
АНЗ.1	Выявление, анализ уязвимостей информационной системы и оперативное устранение вновь выявленных уязвимостей		+	+	+
АНЗ.2	Контроль установки обновлений программного обеспечения, включая обновление программного обеспечения средств защиты информации	+	+	+	+
АНЗ.3	Контроль работоспособности, параметров настройки и правильности функционирования программного обеспечения и средств защиты информации		+	+	+
АНЗ.4	Контроль состава технических средств, программного обеспечения и средств защиты информации		+	+	+
АНЗ.5	Контроль правил генерации и смены паролей пользователей, заведения и удаления учетных записей пользователей, реализации правил разграничения доступа, полномочий пользователей в информационной системе			+	+
IX. Обеспечение целостности информационной системы и персональных данных (ОЦЛ)					

ОЦЛ.1	Контроль целостности программного обеспечения, включая программное обеспечение средств защиты информации			+	+
ОЦЛ.2	Контроль целостности персональных данных, содержащихся в базах данных информационной системы				
ОЦЛ.3	Обеспечение возможности восстановления программного обеспечения, включая программное обеспечение средств защиты информации, при возникновении нештатных ситуаций				
ОЦЛ.4	Обнаружение и реагирование на поступление в			+	+
Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
	информационную систему незапрашиваемых электронных сообщений (писем, документов) и иной информации, не относящихся к функционированию информационной системы (защита от спама)				
ОЦЛ.5	Контроль содержания информации, передаваемой из информационной системы (контейнерный, основанный на свойствах объекта доступа, и (или) контентный, основанный на поиске запрещенной к передаче информации с использованием сигнатур, масок и иных методов), и исключение неправомерной передачи информации из информационной системы			+	
ОЦЛ.6	Ограничение прав пользователей по вводу информации в информационную систему	+	+	+	+
ОЦЛ.7	Контроль точности, полноты и правильности данных, вводимых в информационную систему	+	+	+	+

ОЦЛ.8	Контроль ошибочных действий пользователей по вводу и (или) передаче персональных данных и предупреждение пользователей об ошибочных действиях			+	+
Х. Обеспечение доступности персональных данных (ОДТ)					
ОДТ.1	Использование отказоустойчивых технических средств			+	
ОДТ.2	Резервирование технических средств, программного обеспечения, каналов передачи информации, средств обеспечения функционирования информационной системы	+	+		
ОДТ.3	Контроль безотказного функционирования технических средств, обнаружение и локализация отказов функционирования, принятие мер по восстановлению отказавших средств и их тестирование				+
ОДТ.4	Периодическое резервное копирование			+	+
Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
	персональных данных на резервные машинные носители персональных данных			+	+
ОДТ.5	Обеспечение возможности восстановления персональных данных с резервных машинных носителей персональных данных (резервных копий) в течение установленного временного интервала			+	+
XI. Защита среды виртуализации (ЗСВ)					
ЗСВ.1	Идентификация и аутентификация субъектов доступа и объектов доступа в виртуальной инфраструктуре, в том числе администраторов управления средствами виртуализации	+	+	+	+

ЗСВ.2	Управление доступом субъектов доступа к объектам доступа в виртуальной инфраструктуре, в том числе внутри виртуальных машин	+	+	+	+
ЗСВ.3	Регистрация событий безопасности в виртуальной инфраструктуре		+	+	+
ЗСВ.4	Управление (фильтрация, маршрутизация, контроль соединения, однонаправленная передача) потоками информации между компонентами виртуальной инфраструктуры, а также по периметру виртуальной инфраструктуры				
ЗСВ.5	Доверенная загрузка серверов виртуализации, виртуальной машины (контейнера), серверов управления виртуализацией			+	+
ЗСВ.6	Управление перемещением виртуальных машин (контейнеров) и обрабатываемых на них данных			+	+
ЗСВ.7	Контроль целостности виртуальной инфраструктуры и ее конфигураций			+	+
ЗСВ.8	Резервное копирование данных, резервирование технических средств, программного обеспечения виртуальной инфраструктуры, а также каналов			+	+
Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
	связи внутри виртуальной инфраструктуры			+	+
ЗСВ.9	Реализация и управление антивирусной защитой в виртуальной инфраструктуре		+	+	+

ЗСВ.10	Разбиение виртуальной инфраструктуры на сегменты (сегментирование виртуальной инфраструктуры) для обработки персональных данных отдельным пользователем и (или) группой пользователей		+	+	+
XII. Защита технических средств (ЗТС)					
ЗТС.1	Защита информации, обрабатываемой техническими средствами, от ее утечки по техническим каналам				
ЗТС.2	Организация контролируемой зоны, в пределах которой постоянно размещаются стационарные технические средства, обрабатывающие информацию, и средства защиты информации, а также средства обеспечения функционирования				
ЗТС.3	Контроль и управление физическим доступом к техническим средствам, средствам защиты информации, средствам обеспечения функционирования, а также в помещения и сооружения, в которых они установлены, исключаящие несанкционированный физический доступ к средствам обработки информации, средствам защиты информации и средствам обеспечения функционирования информационной системы, в помещения и сооружения, в которых они установлены	+	+	+	+
ЗТС.4	Размещение устройств вывода (отображения) информации, исключаящее ее несанкционированный просмотр	+	+	+	+
ЗТС.5	Защита от внешних воздействий (воздействий окружающей среды, нестабильности электроснабжения, кондиционирования и иных внешних факторов)				
Условное обозначение	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			

и номер меры		4	3	2	1
XIII. Защита информационной системы, ее средств, систем связи и передачи данных (ЗИС)					
ЗИС.1	Разделение в информационной системе функций по управлению (администрированию) информационной системой, управлению (администрированию) системой защиты персональных данных, функций по обработке персональных данных и иных функций информационной системы				+
ЗИС.2	Предотвращение задержки или прерывания выполнения процессов с высоким приоритетом со стороны процессов с низким приоритетом				
ЗИС.3	Обеспечение защиты персональных данных от раскрытия, модификации и навязывания (ввода ложной информации) при ее передаче (подготовке к передаче) по каналам связи, имеющим выход за пределы контролируемой зоны, в том числе беспроводным каналам связи	+	+	+	+
ЗИС.4	Обеспечение доверенных канала, маршрута между администратором, пользователем и средствами защиты информации (функциями безопасности средств защиты информации)				
ЗИС.5	Запрет несанкционированной удаленной активации видеокамер, микрофонов и иных периферийных устройств, которые могут активироваться удаленно, и оповещение пользователей об активации таких устройств				
ЗИС.6	Передача и контроль целостности атрибутов безопасности (меток безопасности), связанных с персональными данными, при обмене ими с иными информационными системами				

ЗИС.7	Контроль санкционированного и исключение несанкционированного использования технологий мобильного кода, в том числе регистрация событий, связанных с использованием технологий мобильного кода, их				
Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
	анализ и реагирование на нарушения, связанные с использованием технологий мобильного кода				
ЗИС.8	Контроль санкционированного и исключение несанкционированного использования технологий передачи речи, в том числе регистрация событий, связанных с использованием технологий передачи речи, их анализ и реагирование на нарушения, связанные с использованием технологий передачи речи				
ЗИС.9	Контроль санкционированной и исключение несанкционированной передачи видеoinформации, в том числе регистрация событий, связанных с передачей видеoinформации, их анализ и реагирование на нарушения, связанные с передачей видеoinформации				
ЗИС.10	Подтверждение происхождения источника информации, получаемой в процессе определения сетевых адресов по сетевым именам или определения сетевых имен по сетевым адресам				
ЗИС.11	Обеспечение подлинности сетевых соединений (сеансов взаимодействия), в том числе для защиты от подмены сетевых устройств и сервисов			+	+

ЗИС.12	Исключение возможности отрицания пользователем факта отправки персональных данных другому пользователю				
ЗИС.13	Исключение возможности отрицания пользователем факта получения персональных данных от другого пользователя				
ЗИС.14	Использование устройств терминального доступа для обработки персональных данных				
ЗИС.15	Защита архивных файлов, параметров настройки средств защиты информации и программного			+	+
Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
	обеспечения и иных данных, не подлежащих изменению в процессе обработки персональных данных				
ЗИС.16	Выявление, анализ и блокирование в информационной системе скрытых каналов передачи информации в обход реализованных мер или внутри разрешенных сетевых протоколов				
ЗИС.17	Разбиение информационной системы на сегменты (сегментирование информационной системы) и обеспечение защиты периметров сегментов информационной системы			+	+
ЗИС.18	Обеспечение загрузки и исполнения программного обеспечения с машинных носителей персональных данных, доступных только для чтения, и контроль целостности данного программного обеспечения				
ЗИС.19	Изоляция процессов (выполнение программ) в выделенной области памяти				

ЗИС.20	Защита беспроводных соединений, применяемых в информационной системе		+	+	+
XIV. Выявление инцидентов и реагирование на них (ИНЦ)					
ИНЦ.1	Определение лиц, ответственных за выявление инцидентов и реагирование на них			+	+
ИНЦ.2	Обнаружение, идентификация и регистрация инцидентов			+	+
ИНЦ.3	Своевременное информирование лиц, ответственных за выявление инцидентов и реагирование на них, о возникновении инцидентов в информационной системе пользователями и администраторами			+	+
ИНЦ.4	Анализ инцидентов, в том числе определение источников и причин возникновения инцидентов, а также оценка их последствий			+	+
Условное обозначение и номер меры	Содержание мер по обеспечению безопасности персональных данных	Уровни защищенности персональных данных			
		4	3	2	1
ИНЦ.5	Принятие мер по устранению последствий инцидентов			+	+
ИНЦ.6	Планирование и принятие мер по предотвращению повторного возникновения инцидентов			+	+
XV. Управление конфигурацией информационной системы и системы защиты персональных данных (УКФ)					
УКФ.1	Определение лиц, которым разрешены действия по внесению изменений в конфигурацию информационной системы и системы защиты персональных данных		+	+	+
УКФ.2	Управление изменениями конфигурации информационной системы и системы защиты персональных данных		+	+	+

УКФ.3	Анализ потенциального воздействия планируемых изменений в конфигурации информационной системы и системы защиты персональных данных на обеспечение защиты персональных данных и согласование изменений в конфигурации информационной системы с должностным лицом (работником), ответственным за обеспечение безопасности персональных данных		+	+	+
УКФ.4	Документирование информации (данных) об изменениях в конфигурации информационной системы и системы защиты персональных данных		+	+	+

Таблица 4 – Требования приказа ФСБ № 378

Требование	Уровни защищенности персональных данных			
	1	2	3	4
Организация режима обеспечения безопасности помещений, в которых размещена ИСПДн (далее – Помещения)				
Оснащение Помещений входными дверьми с замками, обеспечения постоянного закрытия дверей Помещений на замок и их открытия только для санкционированного прохода, а также опечатывания Помещений по окончании рабочего дня или оборудование Помещений соответствующими техническими устройствами, сигнализирующими о несанкционированном вскрытии Помещений	+	+	+	+
Утверждение правил доступа в Помещения в рабочее и нерабочее время, а также в нештатных ситуациях	+	+	+	+
Утверждение перечня лиц, имеющих право доступа в Помещения	+	+	+	+

Оборудование окон Помещений, расположенных на первых и (или) последних этажах зданий, а также окон Помещений, находящихся около пожарных лестниц и других мест, откуда возможно проникновение в Помещения посторонних лиц, металлическими решетками или ставнями, охранной сигнализацией или другими средствами, препятствующими неконтролируемому проникновению посторонних лиц в помещения	+			
Оборудование окон и дверей Помещений, в которых размещены серверы ИСПДн, металлическими решетками, охранной сигнализацией или другими средствами, препятствующими неконтролируемому проникновению посторонних лиц в помещения	+			
Обеспечение сохранности носителей персональных данных				
Хранение съемных машинных носителей персональных данных в сейфах (металлических шкафах), оборудованных внутренними замками с двумя или более дубликатами ключей и приспособлениями для опечатывания замочных скважин или кодовыми замками. В случае если на съемном машинном носителе персональных данных хранятся только персональные данные в зашифрованном с использованием СКЗИ виде, допускается хранение таких носителей вне сейфов (металлических шкафов)	+	+	+	+
Поэкземплярный учет машинных носителей персональных данных, который достигается путем ведения журнала учета носителей персональных данных с использованием регистрационных (заводских)	+	+	+	+

Требование	Уровни защищенности персональных данных			
	1	2	3	4
номеров				
Ведение электронного журнала сообщений				

Утверждение руководителем оператора списка лиц, допущенных к содержанию электронного журнала сообщений, и поддержание указанного списка в актуальном состоянии	+	+		
Обеспечение ИСПДн автоматизированными средствами, регистрирующими запросы пользователей ИСПДн на получение ПДн, а также факты предоставления ПДн по этим запросам в электронном журнале сообщений	+	+		
Обеспечение ИСПДн автоматизированными средствами, исключающими доступ к содержанию электронного журнала сообщений лиц, не указанных в утвержденном руководителем оператора списке лиц, допущенных к содержанию электронного журнала сообщений	+	+		
Обеспечение периодического контроля работоспособности автоматизированных средств (не реже 1 раза в полгода)	+	+		
Обеспечение ИСПДн автоматизированными средствами, позволяющими автоматически регистрировать в электронном журнале безопасности изменения полномочий сотрудника оператора по доступу к ПДн, содержащимся в ИСПДн	+			
Отражение в электронном журнале безопасности полномочий сотрудников оператора ПДн по доступу к ПДн, содержащимся в ИСПДн. Указанные полномочия должны соответствовать должностным обязанностям сотрудников оператора	+			
Назначение оператором лица, ответственного за периодический контроль ведения электронного журнала безопасности и соответствия отраженных в нем полномочий сотрудников оператора их должностным обязанностям (не реже 1 раза в месяц)	+			
Регламентация и контроль доступа к ПДн				
Разработка и утверждение документа, определяющего перечень лиц, доступ которых к ПДн, обрабатываемым в ИСПДн, необходим для выполнения ими служебных (трудовых) обязанностей	+	+	+	+

Требование	Уровни защищенности персональных данных			
	1	2	3	4
Поддержание в актуальном состоянии документ, определяющий перечень лиц, доступ которых к ПДн, обрабатываемым в ИСПДн, необходим для выполнения ими служебных (трудовых) обязанностей	+	+	+	+
Назначение обладающего достаточными навыками должностного лица (работника) оператора ответственным за обеспечение безопасности персональных данных в информационной системе	+	+	+	
Создание отдельного структурного подразделения, ответственного за обеспечение безопасности ПДн в ИСПДн, либо возложение его функций на одно из существующих структурных подразделений	+			
Проведение анализа целесообразности создания отдельного структурного подразделения, ответственного за обеспечение безопасности ПДн в ИСПДн	+			
Использование средств защиты информации, прошедших процедуру оценки соответствия требованиям законодательства Российской Федерации				
Получение исходных данных для формирования совокупности предположений о возможностях, которые могут использоваться при создании способов, подготовке и проведении атак	+	+	+	+
Формирование и утверждение руководителем оператора совокупности предположений о возможностях, которые могут использоваться при создании способов, подготовке и проведении атак, и определение на этой основе и с учетом типа актуальных угроз требуемого класса средств криптографической защиты информации (далее – СКЗИ)	+	+	+	+

Таблица 5 – Классы СКЗИ

Класс защищённости ПДн	Класс СКЗИ
1	КА*/КВ и выше**
2	КА*/ КВ и выше**/КС1 и выше***
3	КВ и выше**/КС1 и выше***

4	КС1 и выше
---	------------

Примечание:

* в случаях, когда для ИСПДн актуальны угрозы 1 типа;

** в случаях, когда для ИСПДн актуальны угрозы 2 типа;

*** в случаях, когда для ИСПДн актуальны угрозы 3 типа.

Примечание. Конкретные наименования СКЗИ перечисленных классов (КС1, КС2 и т.д.) выбираются согласно выписке из перечня средств защиты информации, сертифицированных ФСБ России (<http://clsz.fsb.ru/certification.htm>).

Требования к некриптографическим средствам защиты информации в зависимости от уровня защищённости ПДн следующие (пункт 12 приказа ФСТЭК № 21) приведены в таблице 6.

Таблица 6 – Требования к некриптографическим средствам защиты информации

Наименование средства защиты информации	Уровень защищённости ПДн			
	1	2	3	4
Средства вычислительной техники	не ниже 5 класса	не ниже 5 класса	не ниже 5 класса	не ниже 6 класса
Системы обнаружения вторжений	не ниже 4 класса	не ниже 4 класса	не ниже 4 класса***	не ниже 5 класса
			не ниже 5 класса****	
Средства антивирусной защиты	не ниже 4 класса	не ниже 4 класса	не ниже 4 класса***	не ниже 5 класса
			не ниже 5 класса****	
Межсетевые экраны	не ниже 3 класса*	не ниже 3 класса*	не ниже 3 класса***	5 класса
	не ниже 4 класса**	не ниже 4 класса**	не ниже 4 класса****	
Проверка наличия недекларированных возможностей	не ниже чем по 4 уровню контроля	не ниже чем по 4 уровню контроля	не ниже чем по 4 уровню контроля*****	—

* - в случае актуальности угроз 1-го или 2-го типов или взаимодействия информационной системы с информационно-телекоммуникационными сетями международного информационного обмена;

****** - в случае актуальности угроз 3-го типа и отсутствия взаимодействия информационной системы с информационно-телекоммуникационными сетями международного информационного обмена;

******* - в случае актуальности угроз 2-го типа или взаимодействия информационной системы с информационно-телекоммуникационными сетями международного информационного обмена и системы обнаружения вторжений и средства антивирусной защиты не ниже 5 класса защиты;

******** - в случае актуальности угроз 3-го типа и отсутствия взаимодействия информационной системы с информационно-телекоммуникационными сетями международного информационного обмена;

********* - в случае актуальности угроз 2-го типа.

Для обеспечения 1 и 2 уровней защищенности персональных данных, а также для обеспечения 3 уровня защищенности персональных данных в информационных системах,

для которых к актуальным отнесены угрозы 2-го типа, применяются средства защиты информации, программное обеспечение которых прошло проверку не ниже чем по 4 уровню контроля отсутствия недекларированных возможностей.

Примечание. Конкретные наименования некриптографических средств защиты информации перечисленных классов защиты (3 класс, 4 класс и т.д.) выбираются из Государственного реестра сертифицированных средств защиты информации № РОСС RU.0001.01БИ00 (реестр размещён на официальном сайте ФСТЭК России (<http://fstec.ru/>) в разделе Техническая защита информация – Сертификация – Реестры).

Средства вычислительной техники выбираются согласно руководящему документу

«Средства вычислительной техники. Защита от несанкционированного доступа к информации Показатели защищенности от несанкционированного доступа к информации», утверждённому 30 марта 1992 г.

Таблица 7 – Основания для исключения/добавления/компенсирования мер базового набора по обеспечению безопасности ПДн

Описание меры	Основания для исключения/добавления/компенсирования
УПД.13 Реализация защищенного удаленного доступа субъектов доступа к объектам доступа через внешние информационно-телекоммуникационные сети	Действие: Исключить из перечня мер Технология обработки информации не предполагает удаленного доступа к ресурсам данных ИС

УПД.14 Регламентация и контроль использования в ИС технологий беспроводного доступа	Действие: Исключить из перечня мер Технология обработки информации не предполагает использования технологий беспроводного доступа к ресурсам данных ИС
УПД.15 Регламентация и контроль использования в ИС мобильных технических средств	Действие: Исключить из перечня мер Технология обработки информации не предполагает использования мобильных технических средств в данных ИС
ЗСВ.1 Идентификация и аутентификация субъектов доступа и объектов доступа в виртуальной инфраструктуре, в том числе администраторов управления средствами виртуализации	Действие: Исключить из перечня мер Технология обработки информации не предполагает использования виртуальной инфраструктуры в данных ИС
ЗСВ.2 Управление доступом субъектов доступа к объектам доступа в виртуальной инфраструктуре, в том числе внутри виртуальных машин	Действие: Исключить из перечня мер Технология обработки информации не предполагает использования виртуальной инфраструктуры в данных ИС
ЗИС.3 Обеспечение защиты информации от раскрытия, модификации и навязывания (ввода ложной информации) при ее передаче (подготовке к передаче) по каналам связи, имеющим выход за пределы КЗ, в том числе беспроводным каналам связи	Действие: Исключить из перечня мер Технология обработки информации не предполагает передачи информации за пределы КЗ

ПЕРЕЧЕНЬ НОРМАТИВНЫХ ДОКУМЕНТОВ

В ходе выполнения задания были использованы положения следующих нормативных документов:

Методический документ. Методика оценки угроз безопасности информации" (утв. ФСТЭК России 05.02.2021)

Банк данных угроз [Электронный ресурс – URL: <https://bdu.fstec.ru/threat>]

Федеральный закон от 26 июля 2017 г. N 187-ФЗ "О безопасности критической информационной инфраструктуры Российской Федерации"

Постановление Правительства РФ от 8 февраля 2018 г. N 127 "Об утверждении Правил категорирования объектов критической информационной инфраструктуры Российской Федерации, а также перечня показателей критериев значимости объектов критической информационной инфраструктуры Российской Федерации и их значений"

Постановление Правительства РФ от 1 ноября 2012 г. N 1119 "Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных".

Приказ от 18 февраля 2013 г. № 21 об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных

Методический документ "Меры защиты информации в государственных информационных системах" (утв. Федеральной службой по техническому и экспортному контролю 11 февраля 2014 г.)

«Методические рекомендации по обеспечению с помощью криптосредств безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств автоматизации» (утверждены руководством 8 Центра ФСБ России 21 февраля 2008 г. № 149/54-144);

ФЗ «О персональных данных» № 152-ФЗ от 27.07.2006 года, далее - 152-ФЗ.